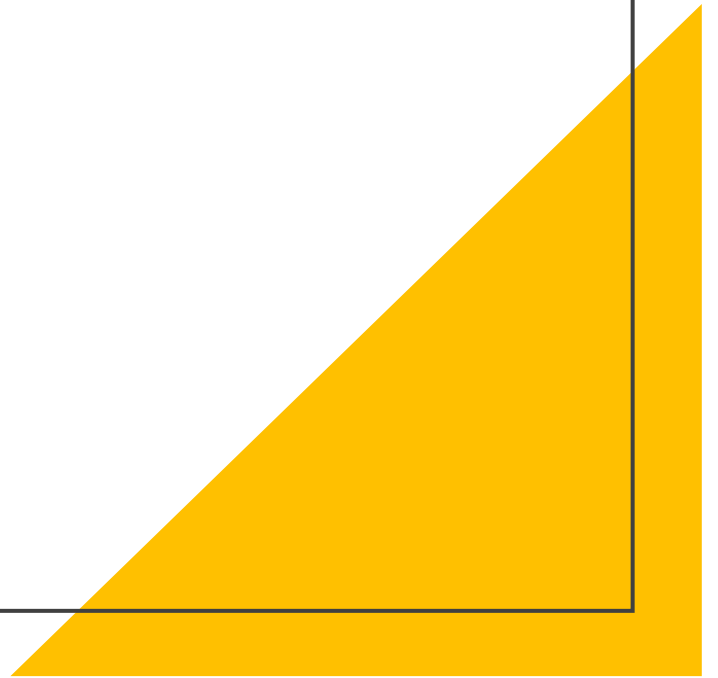


Sociotechnical Security

CS 8803/4803

Professor Veronica Rivera

Lecture 4 – Sociotechnical abuse vectors



Last time

- Why mental models matter in security: UIs often give poor feedback on incorrect mental models. **Insecurity rarely causes an error.**
- Read and discussed two papers on user mental models
 - Talked about some ways to identify mental models
 - Strengths and limitations of interviews and surveys

Example 1: Mental models of encryption

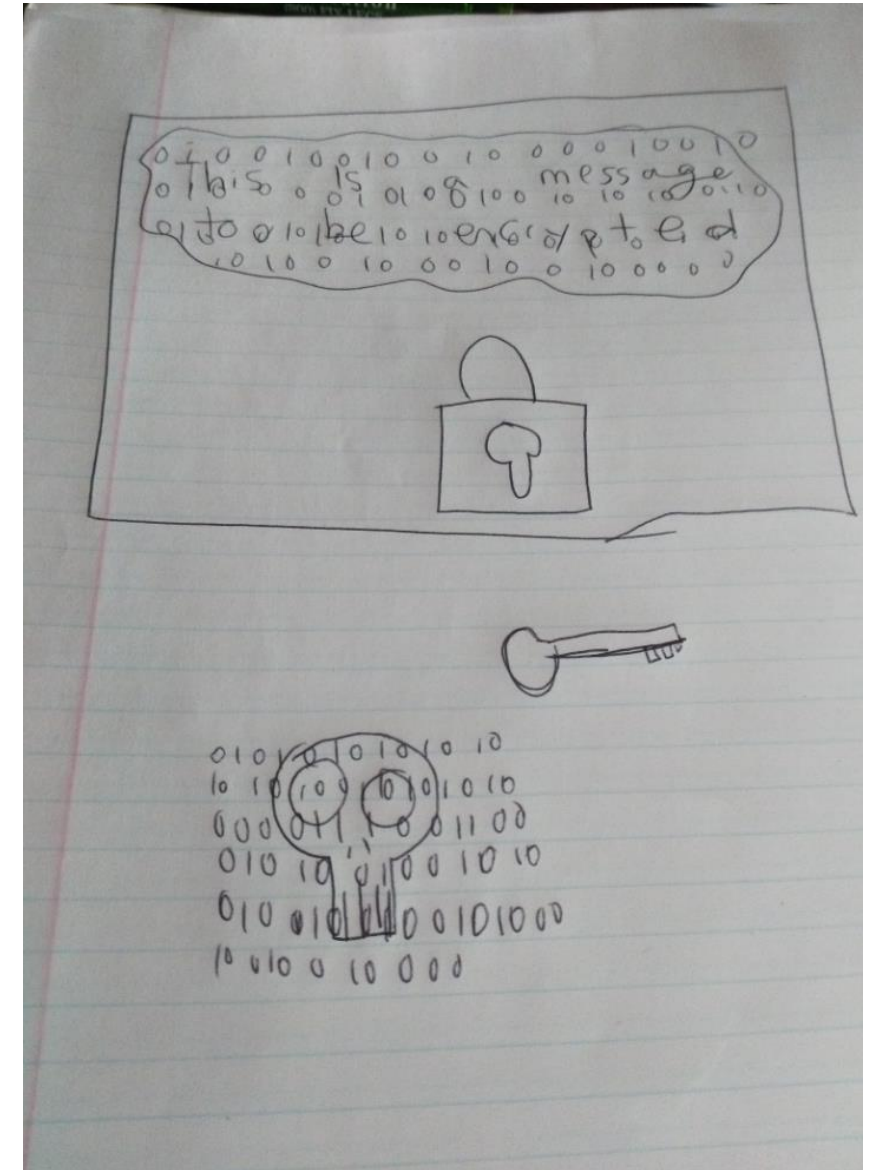
[When is a Tree Really a Truck? Exploring Mental Models of Encryption](#)

[Justin Wu and Daniel Zappala](#) (SOUPS 2018)

- First paper to study users' mental models of encryption
 - *If all you knew was that a tool “used encryption,” what would you understand about it, and how would your mental model guide your efforts to interact with it?*
- Semi-structured phone interviews with 19 participants
 - Standard questions
 - Diagramming activity to visually demonstrate their perception of encryption
- Focused on three dimensions: what encryption is, how it works, and its role in their lives.

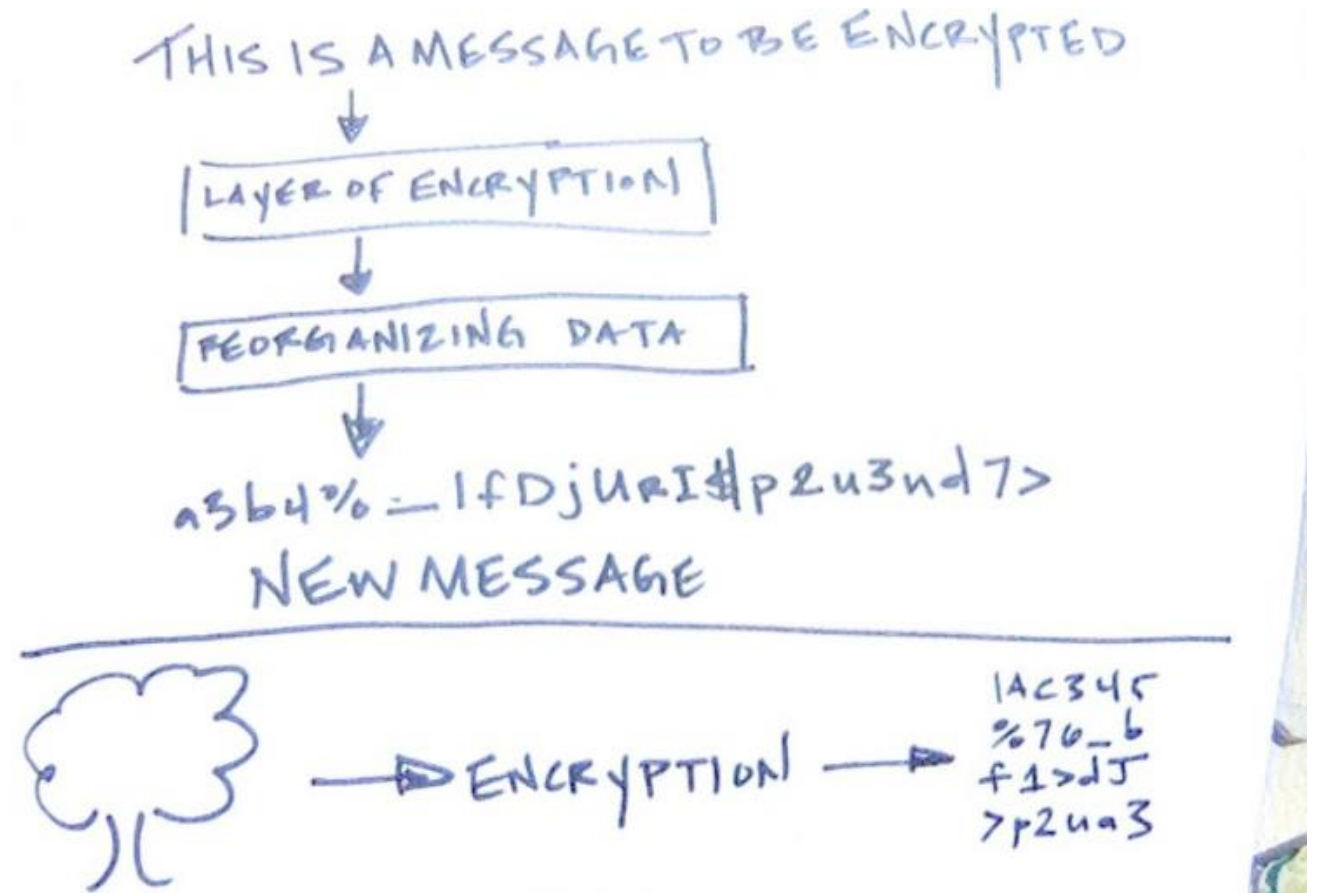
Model 1: Access control

- Encryption does not transform data; it just blocks access
- Encryption is like putting up a wall
- Encryption = locking



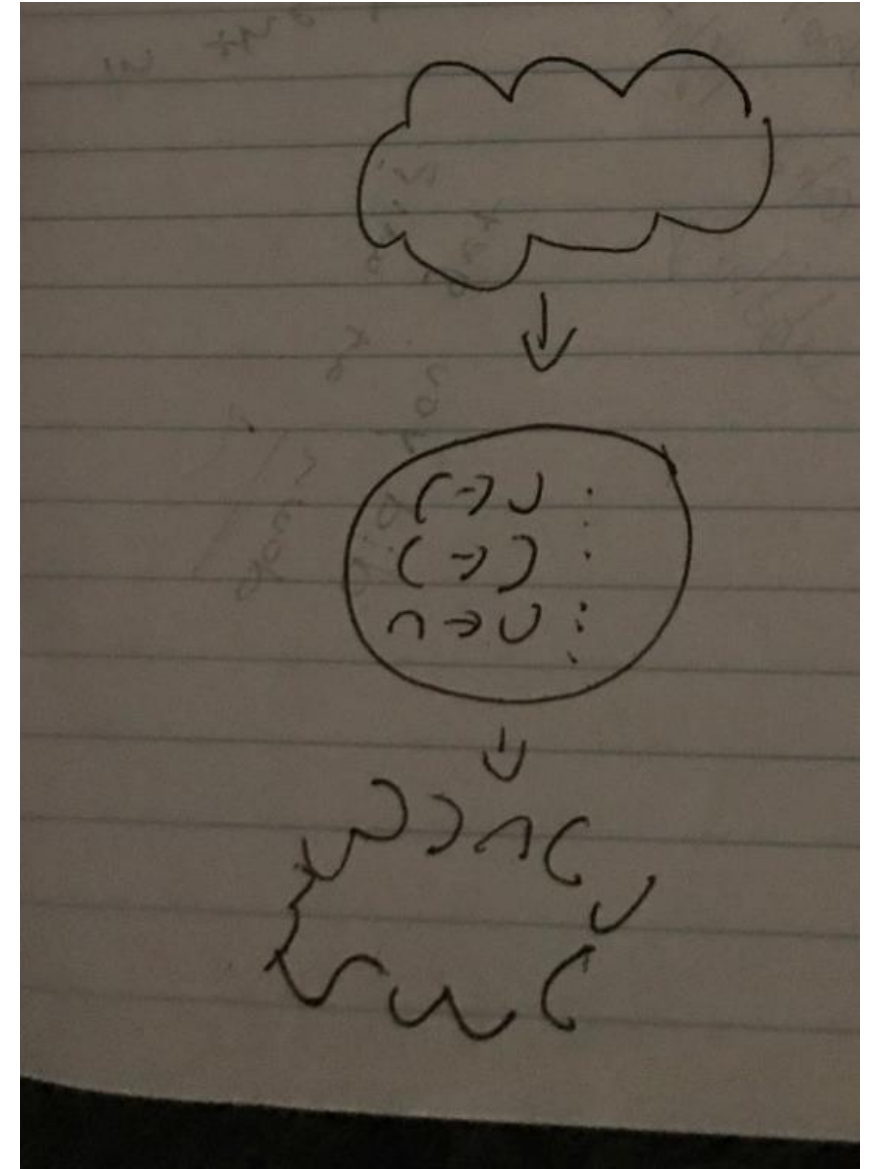
Model 2: Black box

- Conceptually similar to access control: it's about who can get in
- Participants believe data does get altered, just not sure how



Model 3: Cipher

- This model is a (further) refinement
- Encryption transforms data, AND
- That transformation involves substitutions
 - e.g., replacing one character with another
 - NOTE: modern encryption replaces large BLOCKS of characters, and the replacement is position & message-dependent

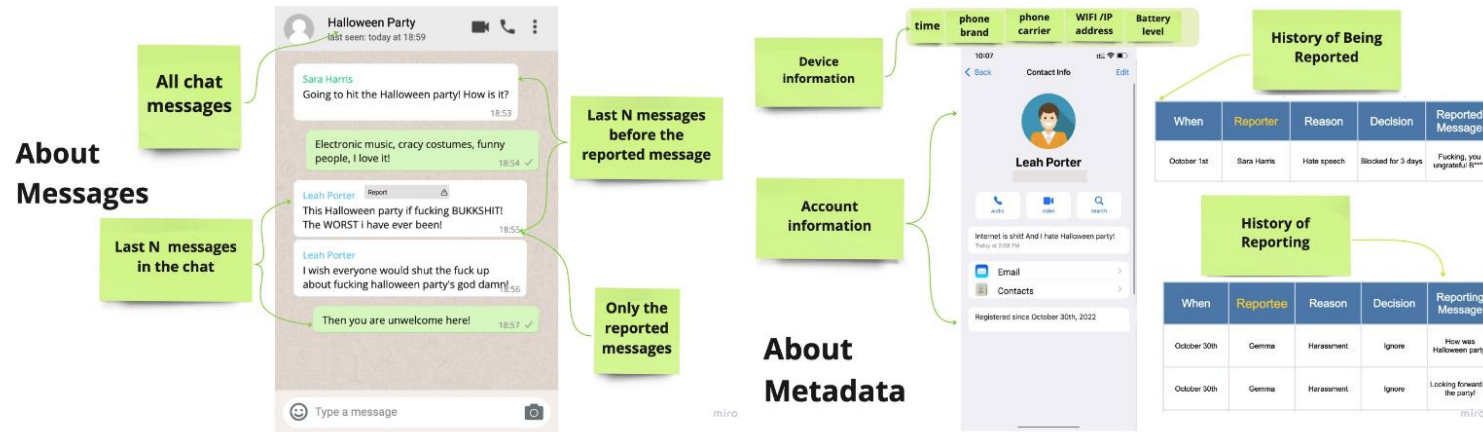


Example 2: Mental models of abuse reporting on E2EE platforms

[“Is Reporting Worth the Sacrifice of Revealing What I’ve Sent”: Privacy Considerations When Reporting on End-to-End Encrypted Platforms \(SOUPS 2023\)](#)

- Interviews with 16 users of E2EE platforms (e.g., WhatsApp, Signal)
 - Card sorting
 - Hypothetical scenarios
- Focused on users’ understanding of data flows
 - What data is shared with E2EE platforms and moderators
 - How the data is stored and used by platforms
 - Related privacy concerns

Card sorting activity



When Reporting to Platform Moderators



Results snapshot: stakeholders' access

- Platforms
 - Most E2EE messaging platforms have access to the reported message and contextual messages, except for Signal
 - When a message is reported platform can access account information and chat information (who you chatted with, frequency, when you chatted)
 - Device information (metadata)
- Platform moderators
 - Often seen as being the same entity as platforms and therefore having the same level of access
- Community moderators
 - Assumed to have the least access of the three, just account age or country
 - Reasoning: community moderators are part of the community already so platform gives them less

Recall:

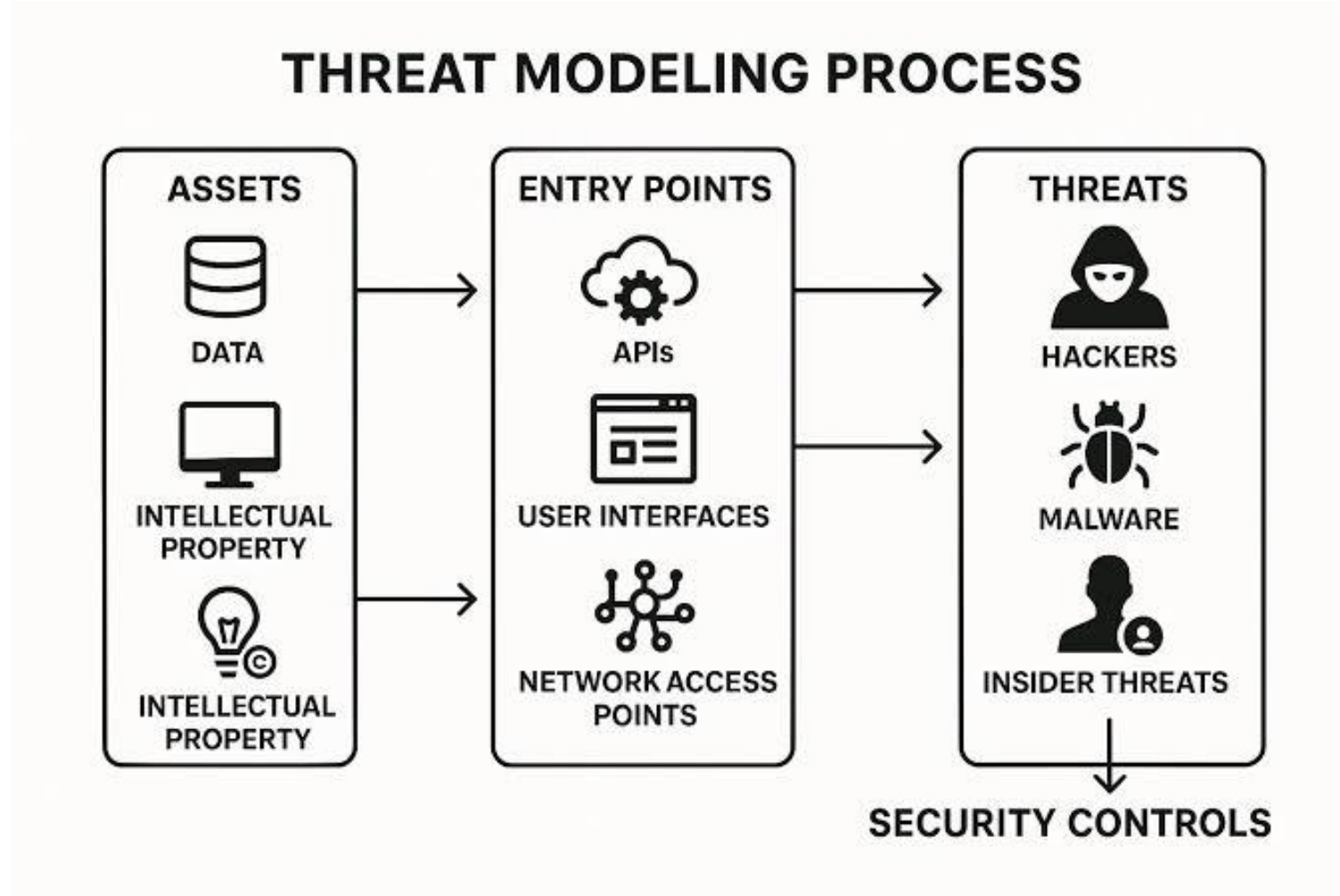
**keep people safe
in their interactions with sociotechnical
systems**

```
graph TD; A["keep people safe  
in their interactions with sociotechnical  
systems"] -- blue line --> B["Usable security and  
privacy"]; A -- green line --> C["Digital safety"];
```

Usable security and
privacy

Digital safety

Threat modeling



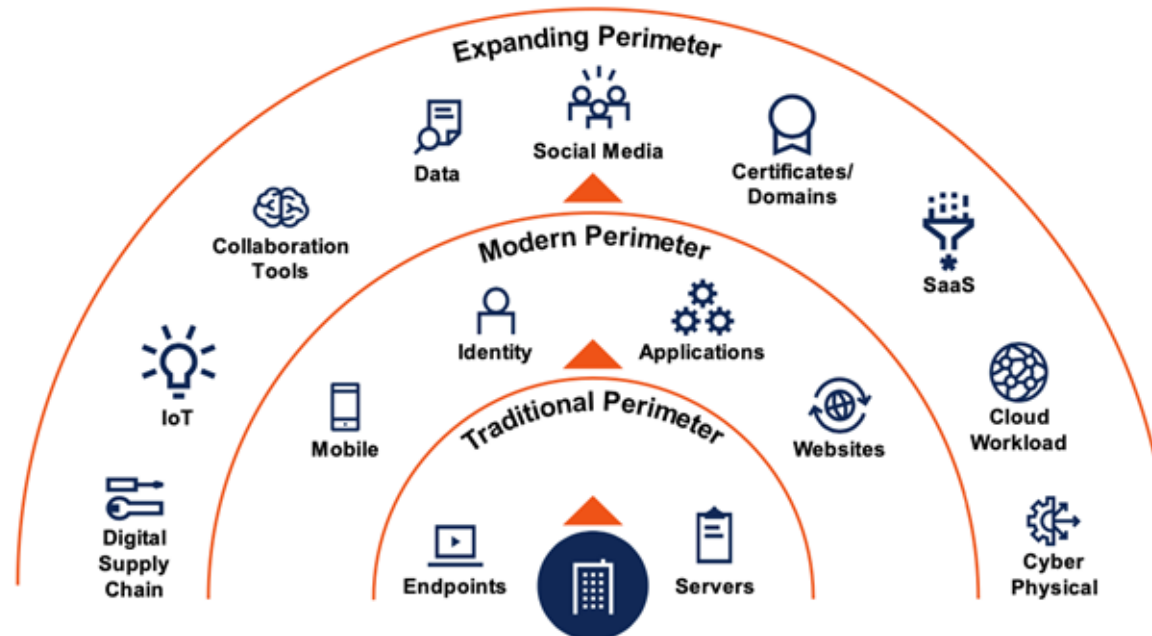
Attack Surface

All possible points where an unauthorized user can access hardware, devices, networks, or applications.

The smaller the surface, the easier to protect – e.g., with zero-trust principles.

Attack Vectors

The specific paths attackers use to reach those points – e.g., phishing, stolen credentials, or unpatched software.



Features → Affordances → Outcomes

design elements that offer specific types of capabilities

possibilities for action available in a given environment

actions or other behaviors connected with user goals

When we think about **entry points for abuse** in a system:

What design elements allow users to create or consume content?

What do these design elements let people do?

What do people do with them, and what are the results?

Discussion

Discussion leading assignment

- You will be assigned as the discussion lead for one class session
- Counts for 25% of your grade, so please do spend time on it
- Read the paper
- Create a 20-25 minute presentation on one of the papers
 - Study motivation, methodology, high-level findings, implications/impact
- Lead the class in discussion
 - Prepare 5 discussion questions that **provoke** the class
 - These can be for just the one paper or for both if there are two
- You are exempt from the reading response when you lead discussion

Example questions

Good questions:

- How do you think the usability of generative AI tools causes security failures?
- Abu-Salma et al., explicitly push back on the “usability is the obstacle” narrative that Johnny Can’t Encrypt helped establish. Are the two papers actually in tension or do they answer different questions?

Bad questions:

- What did everyone think of the reading?
- Do generative AI tools have usability problems that cause security failures?

Discussion Leading Assignments

Name	Topic	Slides due for feedback (at 2 PM ET)	Presentation Date
Raj	Security warning design	September 16	September 21
Salah	Privacy I	September 18	September 23
Akshat	Privacy II	September 23	September 28
Heeyun	Scams I	October 2	October 7
Jedsada	Scams II	October 7	October 12
Muiz	Online hate and harassment	October 14	October 19
Shashwata	Intimate Partner Violence	October 21	October 26
Delaney	S&P for at-risk groups: Activists and Journalists	October 23	October 28
Ishika	Digital Intimacy	October 28	Nov 2
Tsai-Hsuan	Youth Safety I	Nov 4	Nov 9
James	Youth Safety II	Nov 6	Nov 11
Veer	Sociotechnical AI Safety	Nov 11	Nov 16

Final Project

- Work with 1-3 people to conduct original research in Sociotechnical Security
- Worth 50% of your grade
- Two options:
 - **Open-ended research project** on a sociotechnical security topic using any human-centered and/or empirical research methods
 - **Platform harms measurement project**, building an automated detector for identifying harm on a social platform and using the tool to answer a set of research questions

Project Milestones

- Project proposal: ~~Due 9/14~~ Due 9/16
 - Detailed instructions for project proposal will be on the course website by end of the week.
- Midpoint check-in report: Due 10/14
- Final presentation: 12/7 (last day of class)
- Final report: Due 12/7

There are ample opportunities for you to receive help from Veronica on the project.

Project speed dating

2 minute project pitches, use any remaining time to ask each other questions about your ideas

Student	Round 1	Round 2	Round 3	Round 4
Akshat	Heeyun	Shashwata	Veer	Ian
Delaney	Raj	Muiz & Heeyun	Ian	Shashwata
Heeyun	Akshat	Delaney & Muiz	Ishika	Veer
Ian	Shashwata & Jedsada	Tsai-Hsuan	Delaney	Akshat
Ishika	Salah	James	Heeyun	Tsai-Hsuan & Raj
James	Veer	Ishika	Raj	Muiz
Jedsada	Shashwata & Ian	Raj	Tsai-Hsuan	Salah
Muiz	Tsai-Hsuan	Delaney & Heeyun	Salah & Shashwata	James
Raj	Delaney	Jedsada	James	Ishika & Tsai-Hsuan
Salah	Ishika	Veer	Shashwata & Muiz	Jedsada
Shashwata	Jedsada & Ian	Akshat	Salah & Muiz	Delaney
Tsai-Hsuan	Muiz	Ian	Jedsada	Ishika & Raj
Veer	James	Salah	Akshat	Heeyun